

HUGS ID v1.0 to v1.1

Regression & Fix-Verification Review

Second design-level security and architecture review · 4 August 2026

10/10	0	16	10
themes fixed	critical	high residual	medium residual

Bottom Line

Version 1.1 is a strong, competent remediation. All ten Version 1.0 themes are fixed at their core, and no original hole was reintroduced. Every finding in this review is second-order: a residual gap inside a new mechanism or new surface created by the fix.

The most important remaining work is to define the trust anchors beneath the new mechanisms: the published root-key set, the meaning and jurisdiction of a competent guardian-verification authority, and a secure key-loss and compromise-recovery path.

Theme-by-Theme Regression Verdict

#	Original theme	v1.1 verdict	Residual
1	Authority Chains had no cryptographic construction	Fixed	Root-key bootstrap, subset semantics, and staleness bounds remain undefined.
2	Nothing was bound to a key	Fixed	Key-loss recovery and non-webhook signature-suite details remain.
3	Guardianship was asserted, not verified	Fixed	Competent authority, jurisdiction, conflicts, and external-record change detection remain.
4	AI safeguards were documentary	Fixed	Reviewer qualification and permission-class downgrade risk remain.
5	Privacy did not hold for minors	Fixed	Claim-content correlation, central mapping risk, and erasure edge cases remain.
6	API authorization scope was undefined	Fixed	409 and 410 responses may still reveal object existence.
7	Webhook SSRF and exfiltration surface	Fixed	Redirects, IPv6, connect-time validation, and replay-window details remain.
8	No atomicity or fail-closed default	Fixed	Fail-closed and subtree revocation can become a denial-of-service lever.
9	Identifier entropy was underspecified	Fixed	No material residual.
10	Media-rights consent semantics gap	Partial by nature	Downstream revocation is contractual and cannot technically recall distributed copies.

Highest-Value Next Actions

- Define a signed, versioned root-key manifest and authenticated rotation procedure.
- Enumerate competent guardian-verification authorities and bind jurisdiction and delegated scope.
- Add a secure identity-key recovery and re-binding flow.
- Define attenuation subset semantics and maximum chain-state staleness.
- Prevent permission-class downgrade around decide-class safeguards.
- Clarify reviewer qualification, independence, and anti-rubber-stamp conformance checks.
- Tighten webhook redirect, IPv6, replay, and connect-time controls.
- Reconcile signed Event Log entries with erasure-compatible non-personal references.
- Bound the blast radius of fail-closed revocation.

Honesty and Limits

This is a design-level review of specification text, not a code audit or production certification. The automated adversarial validation stage completed only two verdicts before an API failure; the remaining findings were hand-adjudicated against the full Version 1.1 text. The two tool-confirmed findings were the root-key trust anchor and the undefined competent authority.

A data protection impact assessment, privacy counsel review, implementation testing, and independent code security assessment remain required before production deployment.